

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPSec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
-
2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
 - B. Analyze key management and trust models
 - C. Recommend a solution with justification
 - D. Design a high-level implementation workflow
-
4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
- B. Analyze email headers for spoofing indicators
- C. Design an improved detection model (rule-based or ML-based)
- D. Evaluate effectiveness and false positive handling

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools

Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation

INDUSTRY PROBLEM-SOLVING TASK – 1

Title

IPSec Deployment for Secure Multinational Enterprise Branch Communication

Industry Problem

A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public Internet. The organization needs to protect different types of traffic while maintaining both **integrity and confidentiality**.

The enterprise must determine when to use Authentication Header (AH), Encapsulating Security Payload (ESP), or both, select appropriate IPSec modes, and evaluate the performance-security trade-offs.

1. Problem Analysis

Communication between branch offices over the public Internet is exposed to several threats:

- Packet interception
- Traffic modification
- IP spoofing
- Replay attacks
- Confidential data exposure
- Man-in-the-middle attacks
- Unauthorized access

The organization therefore requires:

1. Data confidentiality.
2. Data integrity.
3. Data-origin authentication.
4. Replay protection.
5. Secure branch-to-branch communication.
6. Scalable security management.

IPSec provides these capabilities at the IP layer.

The two major IPSec security protocols are:

Authentication Header (AH)

AH provides:

- Data integrity
- Data-origin authentication
- Anti-replay protection

AH **does not provide encryption or confidentiality.**

Encapsulating Security Payload (ESP)

ESP can provide:

- Confidentiality through encryption
- Data integrity
- Data-origin authentication
- Anti-replay protection

For modern VPN deployments, **ESP is normally preferred** because it can provide both confidentiality and integrity.

2. Traffic Classification

Different enterprise traffic can have different security requirements.

Traffic Type	Recommended Protocol	Reason
Public/non-sensitive monitoring data	ESP or no IPSec depending on policy	Limited confidentiality requirement
Internal business applications	ESP	Confidentiality + integrity
Financial transactions	ESP	Strong confidentiality and integrity
HR information	ESP	Sensitive employee information

Database replication	ESP	Protects confidential database traffic
Voice/video traffic	ESP with appropriate performance configuration	Security with low latency
Highly sensitive inter-branch traffic	ESP	Encryption and authentication
Legacy traffic requiring authenticated but non-encrypted protection	AH, where specifically justified	Integrity/authentication without encryption

Recommendation

For the enterprise described, **ESP should be the default protocol for branch-to-branch VPN communication.**

AH should only be selected when there is a specific requirement for authentication/integrity without encryption and the network environment supports the relevant AH behavior.

Using both AH and ESP is technically possible in certain designs, but it generally adds processing and configuration complexity. In most modern deployments, ESP with authenticated encryption provides the required security without needing AH.

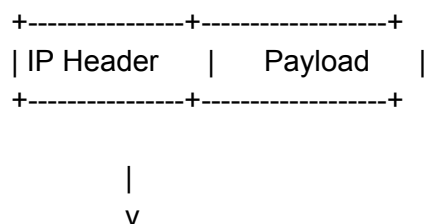
3. IPSec Modes

IPSec supports two major modes:

A. Transport Mode

Transport mode protects the IP payload while leaving the original IP header visible.

Original IP Packet



Transport Mode



Transport mode is commonly useful for host-to-host communication where the endpoints themselves implement IPsec.

Advantages

- Lower overhead.
- Lower bandwidth consumption.
- Lower processing requirement.

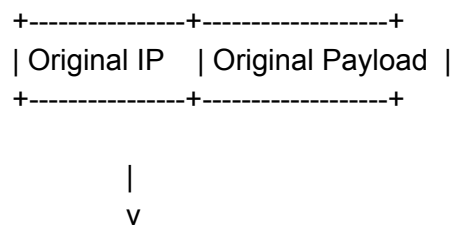
Disadvantage

The original IP addresses remain visible.

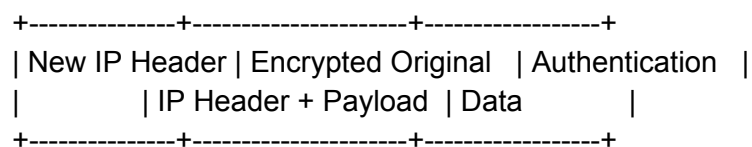
4. Tunnel Mode

Tunnel mode protects the entire original IP packet and encapsulates it inside a new IP packet.

Original Packet

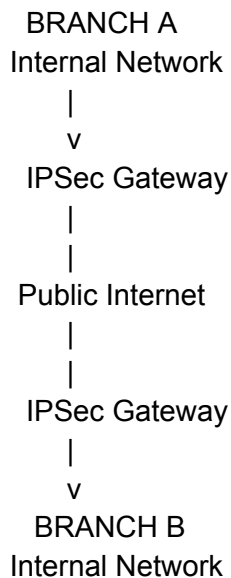


Tunnel Mode

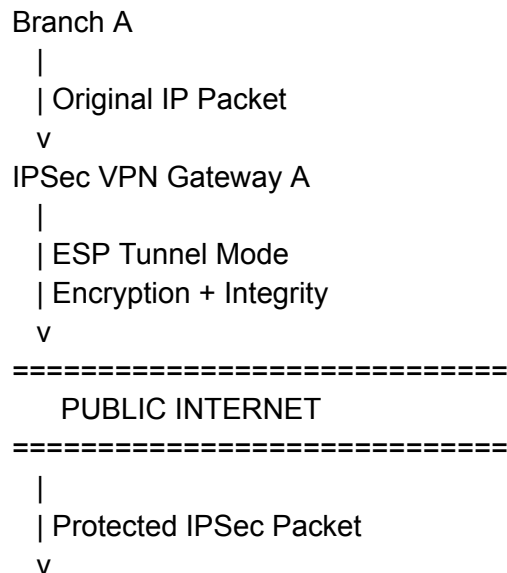


Tunnel mode is especially appropriate for **site-to-site VPNs** connecting branch offices.

5. Recommended Branch-to-Branch Architecture



Detailed packet flow:



IPSec VPN Gateway B
|
| Decrypt + Authenticate
v
Branch B

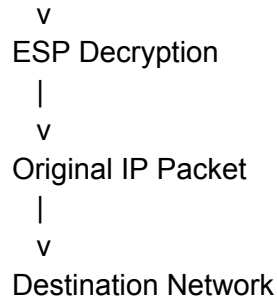
6. Packet Flow

Sender Side

Application Data
|
v
Original IP Packet
|
v
IPSec Policy Check
|
v
ESP Processing
|
+--> Encryption
|
+--> Integrity/Authentication
|
v
New Tunnel IP Header
|
v
Public Internet

Receiver Side

Internet
|
v
IPSec Gateway
|
v
ESP Authentication
|



7. Security Association

Before protected communication begins, IPSec endpoints establish **Security Associations (SAs)**.

An SA defines parameters such as:

- Security protocol.
- Encryption algorithm.
- Integrity/authentication algorithm.
- Keys.
- Lifetime.
- Security parameters.

A simplified SA can be represented as:

SA
|
+-- Protocol: ESP
+-- Mode: Tunnel
+-- Encryption: AES
+-- Integrity: SHA-256/HMAC or authenticated encryption
+-- Key Lifetime
+-- Replay Protection

In practical deployments, **IKE/IKEv2** is used to negotiate and establish the cryptographic parameters and keys.

8. Protocol Selection

ESP

ESP should be selected for:

- Financial data.
- Database traffic.
- Internal enterprise applications.
- File transfers.
- Email traffic crossing untrusted networks.
- Voice/video traffic requiring confidentiality.

ESP provides the best combination of confidentiality and integrity for the stated enterprise requirement.

AH

AH may be used where:

- Encryption is not required.
- Authentication and integrity are the primary requirements.
- The deployment specifically supports AH.

However, AH is less suitable for typical Internet VPN deployments because it does not provide confidentiality and can interact poorly with NAT environments.

9. Performance vs Security Trade-Off

Factor	AH	ESP
Encryption	No	Yes
Integrity	Yes	Yes
Authentication	Yes	Yes
Confidentiality	No	Yes

Processing overhead	Lower	Higher
Suitable for VPN	Limited	Highly suitable
Sensitive data	Not sufficient alone	Recommended
NAT compatibility	Poorer	Better with NAT-T
Modern VPN usage	Less common	Common

ESP introduces encryption and therefore requires additional processing.

However, modern hardware often provides cryptographic acceleration, significantly reducing the performance impact.

10. Performance Optimization

The organization can reduce performance overhead by:

1. Using hardware-assisted cryptography.
 2. Using AES-based authenticated encryption where appropriate.
 3. Selecting suitable key lifetimes.
 4. Avoiding unnecessary double encryption.
 5. Using efficient tunnel gateways.
 6. Monitoring CPU and network utilization.
 7. Applying IPSec only to traffic that requires protection.
 8. Using appropriate Quality of Service (QoS) policies for real-time traffic.
-

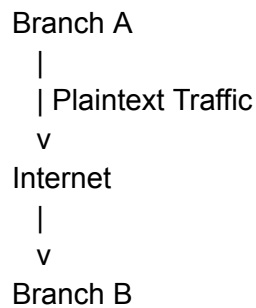
11. Proposed Enterprise Configuration

Requirement	Recommended Configuration
Branch-to-branch VPN	ESP
IPSec mode	Tunnel mode
Key management	IKEv2

Encryption	AES-based encryption
Integrity	Authenticated encryption or HMAC-based integrity as appropriate
Anti-replay	Enabled
Key rotation	Automatic
Sensitive traffic	Mandatory IPSec
Voice/video	ESP with performance optimization
Public Internet	IPSec tunnel

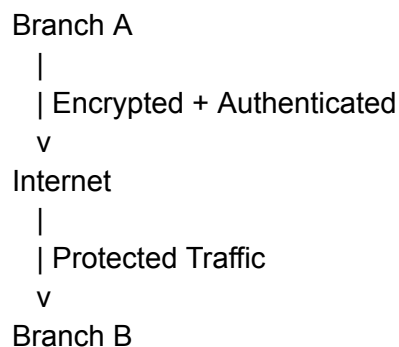
12. Risk Analysis

Without IPSec:



Attackers may potentially intercept or modify traffic.

With ESP:



Confidential information is protected from ordinary network interception, and unauthorized modification can be detected.

13. Expected Outcome

The proposed IPSec architecture provides:

- Confidentiality for sensitive enterprise traffic.
 - Integrity protection.
 - Data-origin authentication.
 - Replay protection.
 - Secure branch-to-branch connectivity.
 - Scalable VPN deployment.
 - Appropriate protection for different traffic types.
 - A balance between security and network performance.
-

14. Conclusion

For the multinational enterprise, **ESP in tunnel mode should be the primary IPSec configuration for branch-to-branch communication**. It provides confidentiality, integrity, authentication, and anti-replay protection while protecting the original IP packet inside the VPN tunnel.

AH can provide integrity and authentication but does not provide confidentiality and is therefore not the preferred choice for sensitive branch-to-branch communication.

Using **IKEv2 for automated key management**, appropriate ESP security parameters, replay protection, and hardware-assisted cryptography provides a scalable solution that balances security and performance.

INDUSTRY PROBLEM-SOLVING TASK – 3

Title

Evaluation and Recommendation of PGP vs S/MIME for Secure Financial Email Communication

Industry Problem

A financial services company needs secure email communication for sensitive transactions. The organization must select between **Pretty Good Privacy (PGP)** and **S/MIME** based on usability, scalability, key management, trust models, and enterprise integration.

1. Problem Analysis

Financial organizations exchange sensitive information such as:

- Transaction instructions.
- Account information.
- Financial reports.
- Customer information.
- Internal business documents.
- Payment-related communication.

Ordinary email does not automatically provide end-to-end cryptographic protection.

The organization therefore needs:

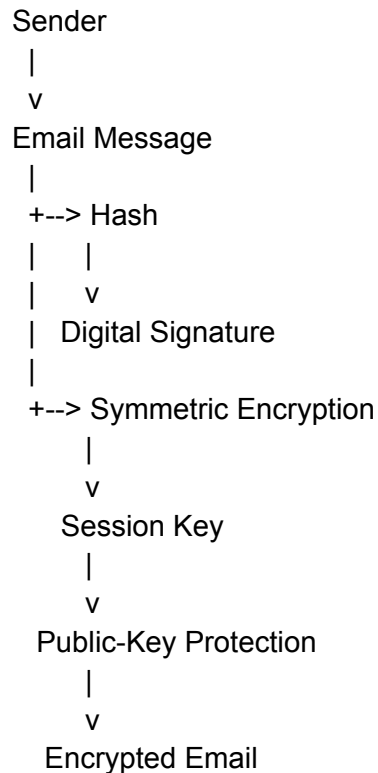
1. Confidentiality.
2. Integrity.
3. Authentication.
4. Digital signatures.
5. Non-repudiation.
6. Centralized management.
7. Scalable certificate/key management.

Two important technologies are **PGP** and **S/MIME**.

2. PGP

Pretty Good Privacy (PGP) is a cryptographic system that can provide email encryption and digital signatures using public-key cryptography.

A simplified PGP workflow is:



PGP commonly uses a hybrid approach:

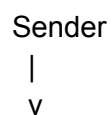
- Symmetric cryptography encrypts the message.
- Public-key cryptography protects the session key.
- Digital signatures provide authentication and integrity.

3. S/MIME

S/MIME (Secure/Multipurpose Internet Mail Extensions) provides cryptographic protection for email using digital certificates and public-key cryptography.

S/MIME typically relies on a **Public Key Infrastructure (PKI)**.

Simplified workflow:



Email
|
v
Digital Signature
|
v
Certificate
|
v
Encryption
|
v
Secure Email
|
v
Receiver
|
v
Certificate Validation
|
v
Signature Verification
|
v
Decryption

4. PGP vs S/MIME

Feature	PGP	S/MIME
Main trust model	User-managed / web-of-trust or configured trust	Certificate Authority / PKI
Digital signatures	Yes	Yes
Encryption	Yes	Yes
Authentication	Yes	Yes
Enterprise management	More complex	Generally easier with centralized PKI

Certificate infrastructure	Not inherently required in the same way as S/MIME	Required
Key management	User-focused	Organization/PKI-focused
Email client integration	Depends on software/client	Broad enterprise support
Centralized control	More difficult	Strong
Large enterprise deployment	More operational complexity	Generally well suited
User experience	Can require additional setup	Often integrated into enterprise email environments

5. Key Management Comparison

PGP

PGP can use a decentralized trust model.

Users may:

- Generate their own key pairs.
- Exchange public keys.
- Verify fingerprints.
- Establish trust relationships.

Simplified model:

User A

|

| Trust

v

User B

|

| Trust

v

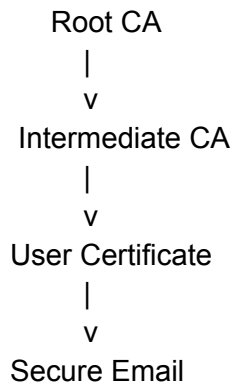
User C

This provides flexibility but can make centralized enterprise management more complicated.

6. S/MIME Trust Model

S/MIME generally uses certificates issued by trusted **Certificate Authorities (CAs)**.

Example:



The receiving system validates:

- Certificate signature.
- Certificate validity period.
- Certificate chain.
- Key usage.
- Certificate revocation status according to applicable validation mechanisms.
- Trust anchor.

This centralized model is particularly useful for enterprise environments.

7. Usability Analysis

PGP Advantages

- Flexible.
- Strong cryptographic protection.

- User-controlled key management.
- Suitable for communities requiring decentralized trust.

PGP Disadvantages

- Key management can be difficult for ordinary users.
- Public-key distribution may require additional processes.
- Trust relationships can become complicated in large organizations.
- Enterprise administration can be more difficult.

S/MIME Advantages

- Integrates well with many enterprise email environments.
- Uses certificates to establish identity.
- Centralized certificate management is possible.
- Suitable for organizations with existing PKI infrastructure.

S/MIME Disadvantages

- Requires certificate lifecycle management.
 - Certificates must be renewed and revoked.
 - Incorrect trust configuration can cause validation failures.
 - Dependence on CA/PKI infrastructure increases administrative requirements.
-

8. Scalability Analysis

For a small group:

PGP

|

+-- User A

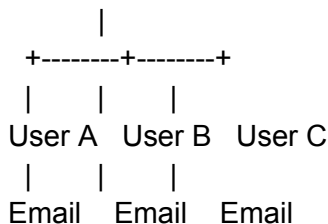
+-- User B

+-- User C

PGP can be practical because users can manage a relatively small number of keys.

For a large enterprise:

Enterprise PKI



S/MIME can be more suitable because certificate issuance and lifecycle management can be centrally controlled.

9. Security Comparison

Security Requirement	PGP	S/MIME
Confidentiality	Yes	Yes
Integrity	Yes	Yes
Authentication	Yes	Yes
Digital Signature	Yes	Yes
Non-repudiation	Yes, subject to key control and policy	Yes, subject to certificate/key control and policy
Centralized identity	Less inherent	Strong PKI model
Enterprise policy enforcement	More complex	Easier with PKI integration

10. Recommendation

For the **financial services company**, **S/MIME is recommended** as the primary secure email technology.

The main reasons are:

1. Enterprise Integration

S/MIME integrates well with enterprise email systems and organizational identity infrastructure.

2. Centralized Certificate Management

Certificates can be issued, renewed, suspended, and revoked using an enterprise PKI.

3. Strong Authentication

Certificates associate public keys with organizational identities.

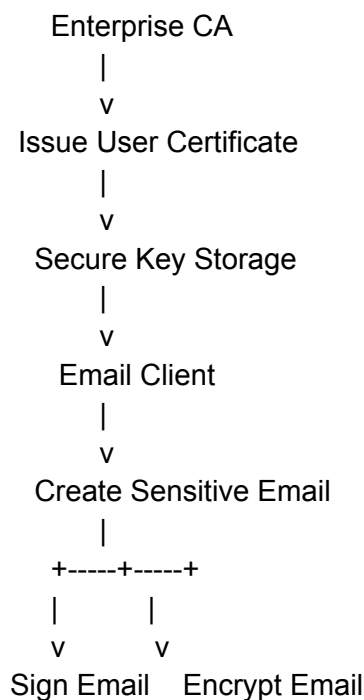
4. Scalability

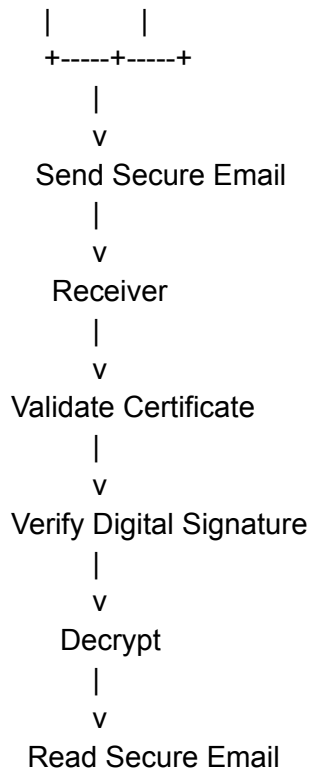
Centralized PKI is better suited for managing a large number of employees and devices.

5. Policy Enforcement

The organization can establish centralized security policies for certificate usage and email protection.

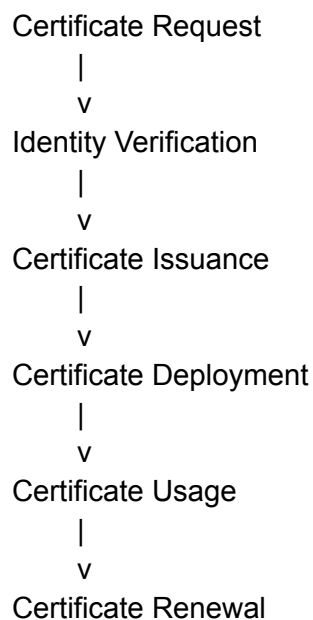
11. Recommended S/MIME Implementation Workflow

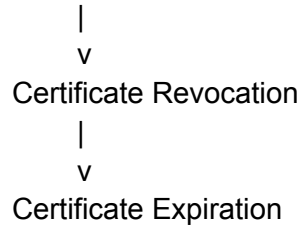




12. Certificate Management

The company should implement a complete certificate lifecycle:





Certificates should be revoked when:

- Private keys are compromised.
 - Employees leave the organization.
 - Devices are lost or compromised.
 - Identity information changes.
 - Security policy requires revocation.
-

13. Secure Key Storage

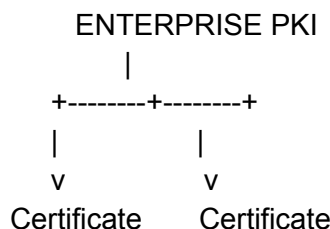
Private keys must be strongly protected.

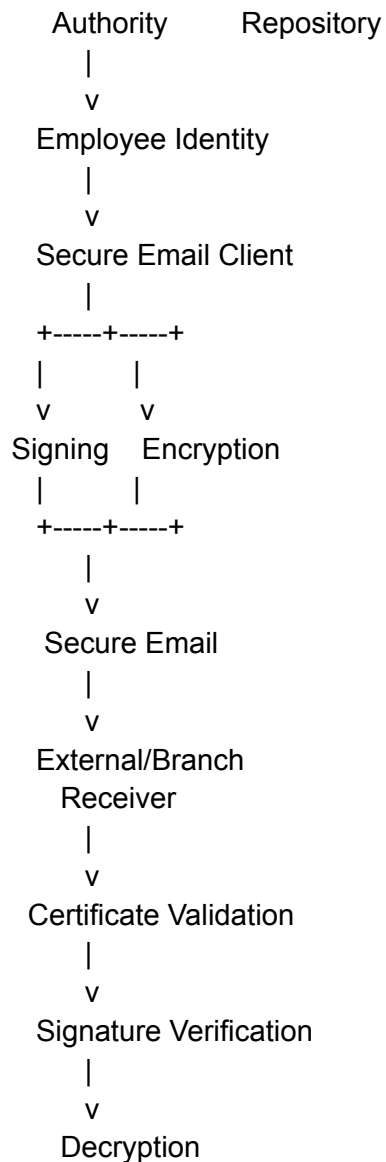
Recommended controls include:

- OS-protected credential/key stores.
- Hardware-backed key storage where appropriate.
- Strong access controls.
- Device security.
- Multi-factor authentication for administrative access.
- Backup and recovery procedures consistent with organizational security policy.

Private keys should never be distributed through email or stored as ordinary plaintext files.

14. High-Level Enterprise Architecture





15. Performance and Operational Considerations

Cryptographic operations introduce some computational overhead.

The organization can manage this by:

1. Using modern email clients with optimized cryptographic libraries.
2. Using efficient symmetric encryption for message content.

3. Using public-key cryptography primarily for key protection and signatures.
4. Automating certificate management.
5. Monitoring certificate expiration.
6. Using centralized enterprise PKI services.

The biggest operational challenge is usually not the encryption itself but **certificate and key lifecycle management**.

16. Final Recommendation

Requirement	Recommendation
Enterprise email	S/MIME
Centralized trust	S/MIME
Existing PKI	S/MIME
Large number of users	S/MIME
Decentralized trust	PGP
User-controlled keys	PGP
Enterprise policy enforcement	S/MIME
Financial organization	S/MIME

PGP remains a strong option where decentralized trust, user-managed keys, or interoperability requirements make it preferable. However, for the described financial enterprise, S/MIME provides a more manageable **certificate-based enterprise trust model**.

17. Expected Outcome

After deploying S/MIME:

- Sensitive emails can be encrypted.
- Senders can digitally sign messages.
- Recipients can verify sender identity.

- Message modifications can be detected.
 - Certificate-based trust can be centrally managed.
 - Enterprise security policies can be enforced.
 - Key and certificate lifecycle management can be standardized.
-

18. Conclusion

For a financial services company handling sensitive transactions, **S/MIME is the recommended solution** because it provides strong email encryption and digital signatures while integrating effectively with enterprise PKI and identity management.

PGP provides excellent cryptographic security and flexible trust models, but its decentralized key-management approach can introduce additional operational complexity in a large organization.

Therefore, an enterprise S/MIME deployment with a properly managed **PKI, secure private-key storage, certificate lifecycle management, certificate validation, revocation procedures, and user security awareness** provides a practical and scalable approach to secure financial email communication.

Overall Conclusion

The two industry problems demonstrate two important aspects of network security.

Problem 1 establishes that IPSec **ESP in tunnel mode with automated IKE-based key management** is generally the preferred architecture for securing multinational branch-to-branch traffic over the public Internet.

Problem 3 establishes that **S/MIME with enterprise PKI** is generally the better choice for a financial organization requiring scalable, centrally managed secure email communication.

Both solutions combine strong cryptographic mechanisms with appropriate **key management, authentication, integrity protection, confidentiality, and enterprise security policies**.